

Risk Acceptance Criteria :VertexOne Digital Services

Prepared by: Junior GRC Analyst

Status: Draft for Risk Committee Approval

Reference: ISO/IEC 27001:2022 Clause 6.1.3

Purpose

Defines the minimum requirements for formally accepting residual information security risks.

Acceptance Criteria

A risk may be accepted when:

1. **Residual Risk:** The risk falls within the organization's approved risk appetite, generally Low or approved Low-Medium.
2. **Justification:** The risk owner documents why further treatment is not currently justified.
3. **Approval:** The accountable risk owner formally approves the acceptance.
4. **Review:** A defined review date is established. Risk acceptance must not be indefinite.

Current Accepted Risk

Risk ID	Asset	Residual Score	Rating	Justification	Accepted By	Review
R-014	Singapore HQ Office Network	3	Low	Existing badge access control reduces likelihood to rare; the cost of an individual audit trail upgrade currently exceeds the expected risk reduction benefit.	CISO	Annually, or upon office relocation

Reassessment Triggers

An accepted risk must be reassessed following:

- Significant changes to the asset or process
- Material changes to the threat landscape
- A relevant security incident
- Changes to legal, regulatory, or contractual requirements
- The scheduled review date

Related Artifact: Risk Acceptance Register